Update Conference Krakow 2026

Beyond Trust: Building Community-Driven Security Analysis for Your .NET Software Supply Chain

Niels Tanis

Security Researcher & Engineer

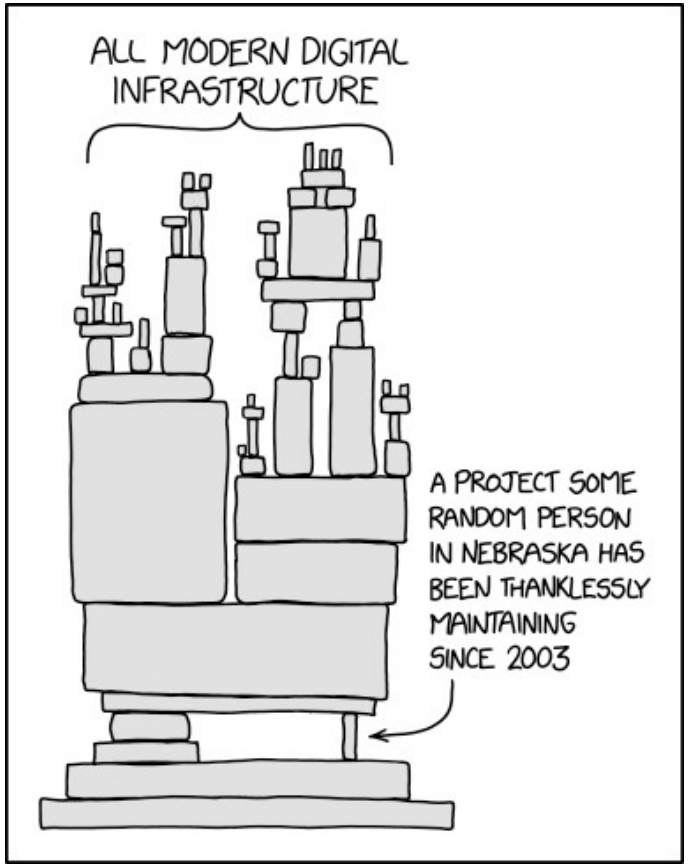
TIDALIS

Who am I?

#UCK26

- Niels Tanis
- Security Researcher & Engineer
  - Background .NET Development, Pentesting/ethical hacking, and software security consultancy
  - Decade of research on static analysis for .NET apps
  - Principal Software Security Engineer at Tidalis
- Microsoft MVP – Developer Technologies

Modern Application Architecture
XKCD 2347

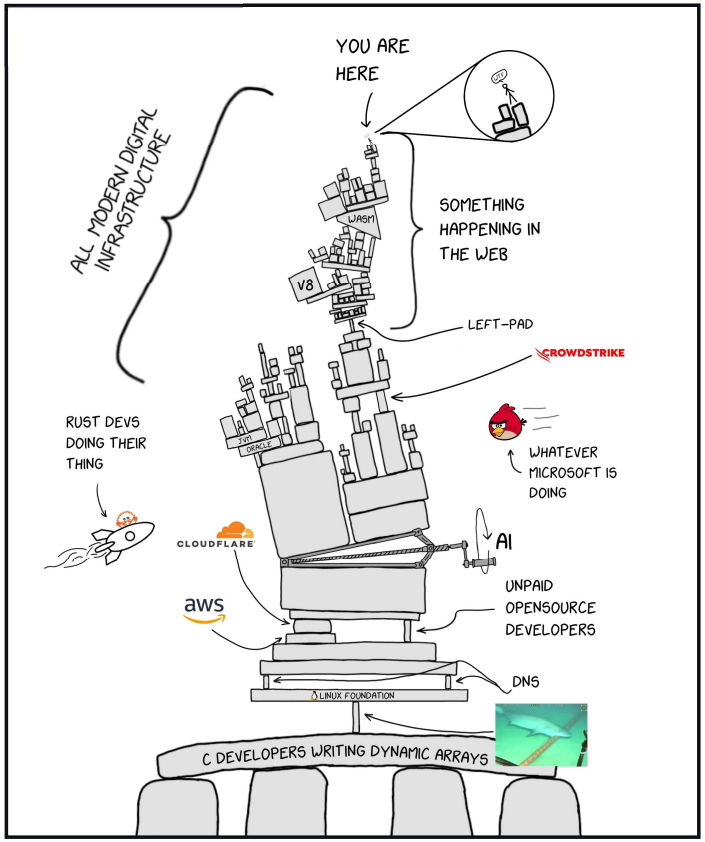


TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

You are here

#UCK26



TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

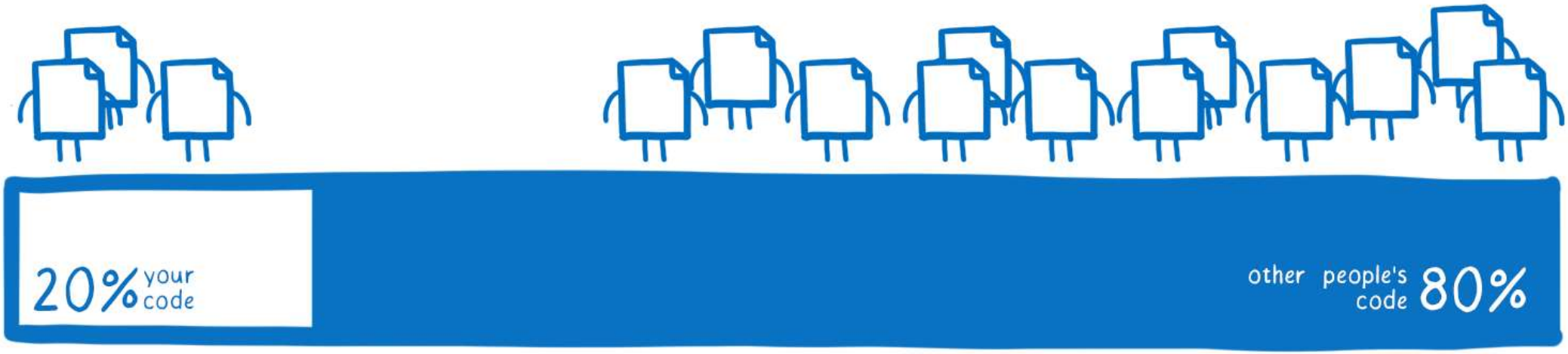
Agenda

#UCK26

- Security challenges in our .NET software supply chain
- How can we start securing our supply-chain?
- Fennec Labs
  - Understanding what projects do for security
  - Know what's inside package
  - Review package
  - Future and idea's
- Conclusion and Q&A

Average codebase composition

#UCK26



TIDALIS

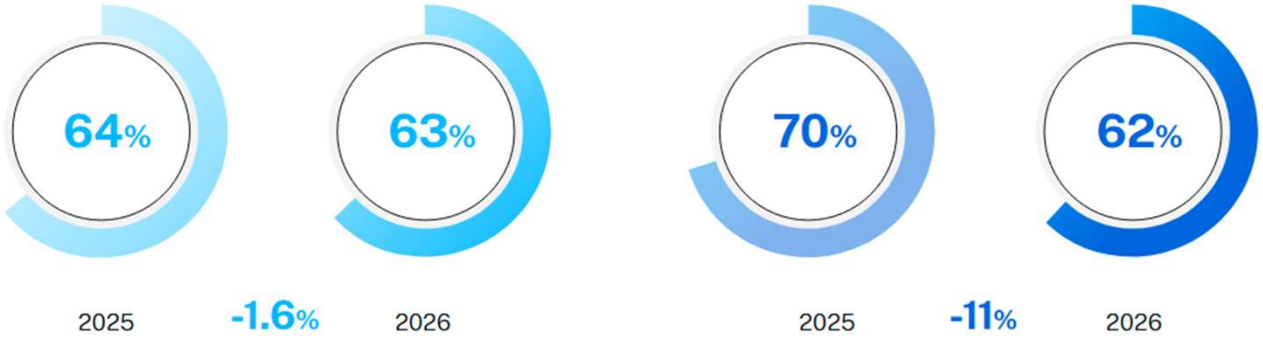
@niels.fennec.dev @nielstanis@infosec.exchange

Veracode State Of Software Security 2026

#UCK26

Prevalence of flaws in first-party (left) vs. third-party (right) code among applications

Percentage of flaws

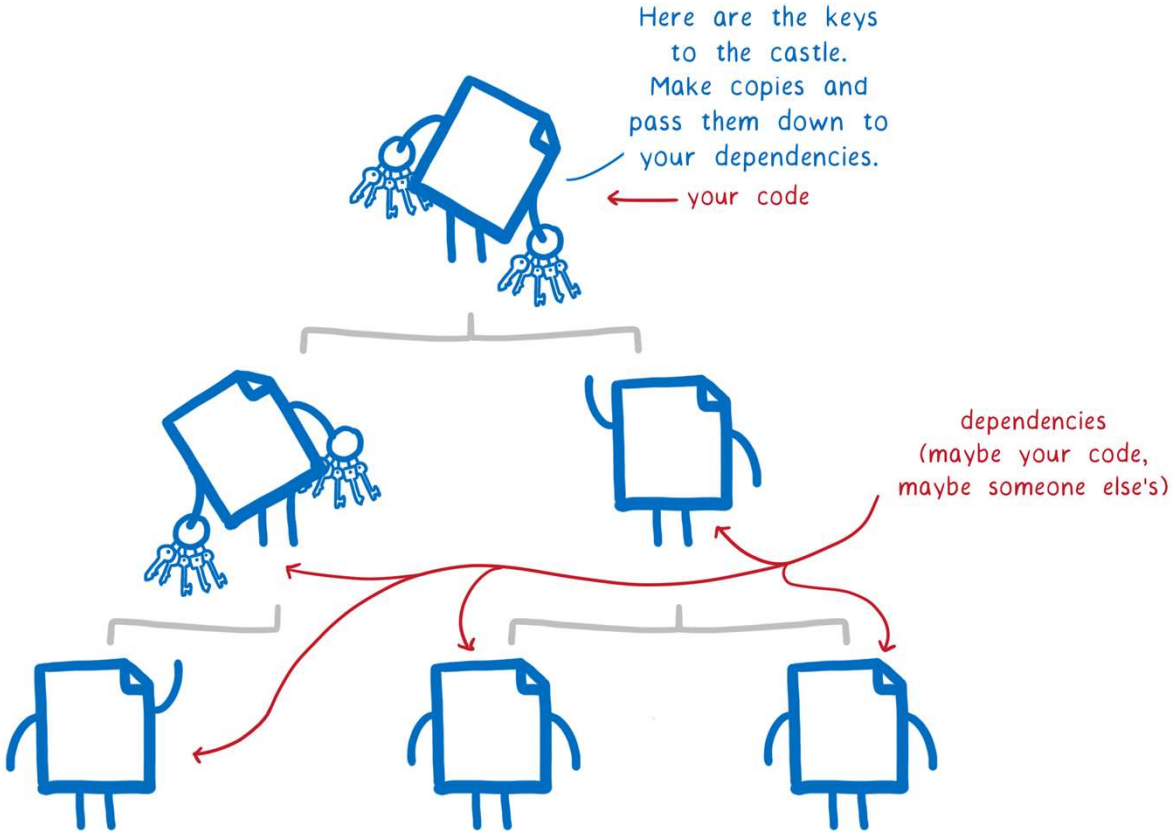


TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

Average codebase composition

#UCK26

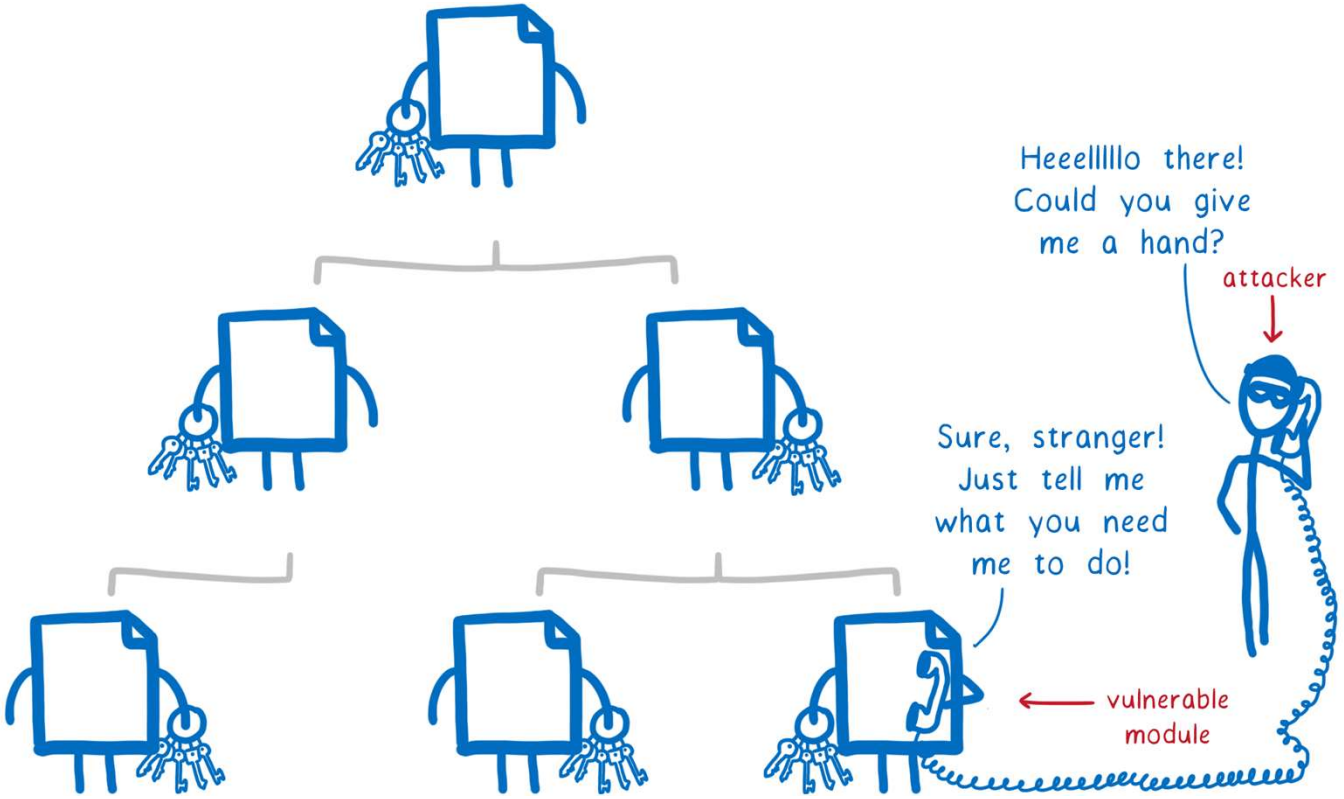


TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

Vulnerable Assembly

#UCK26

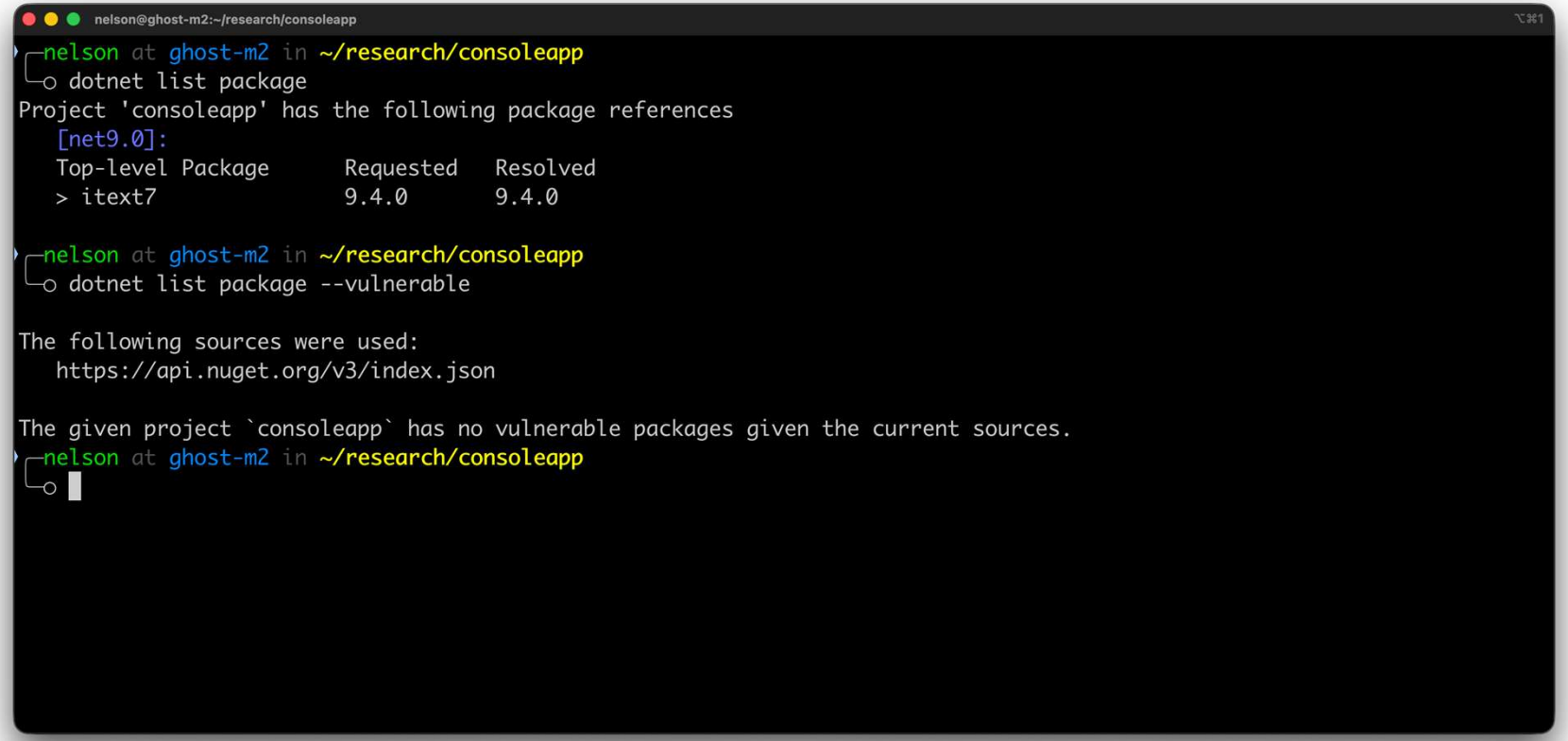


TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

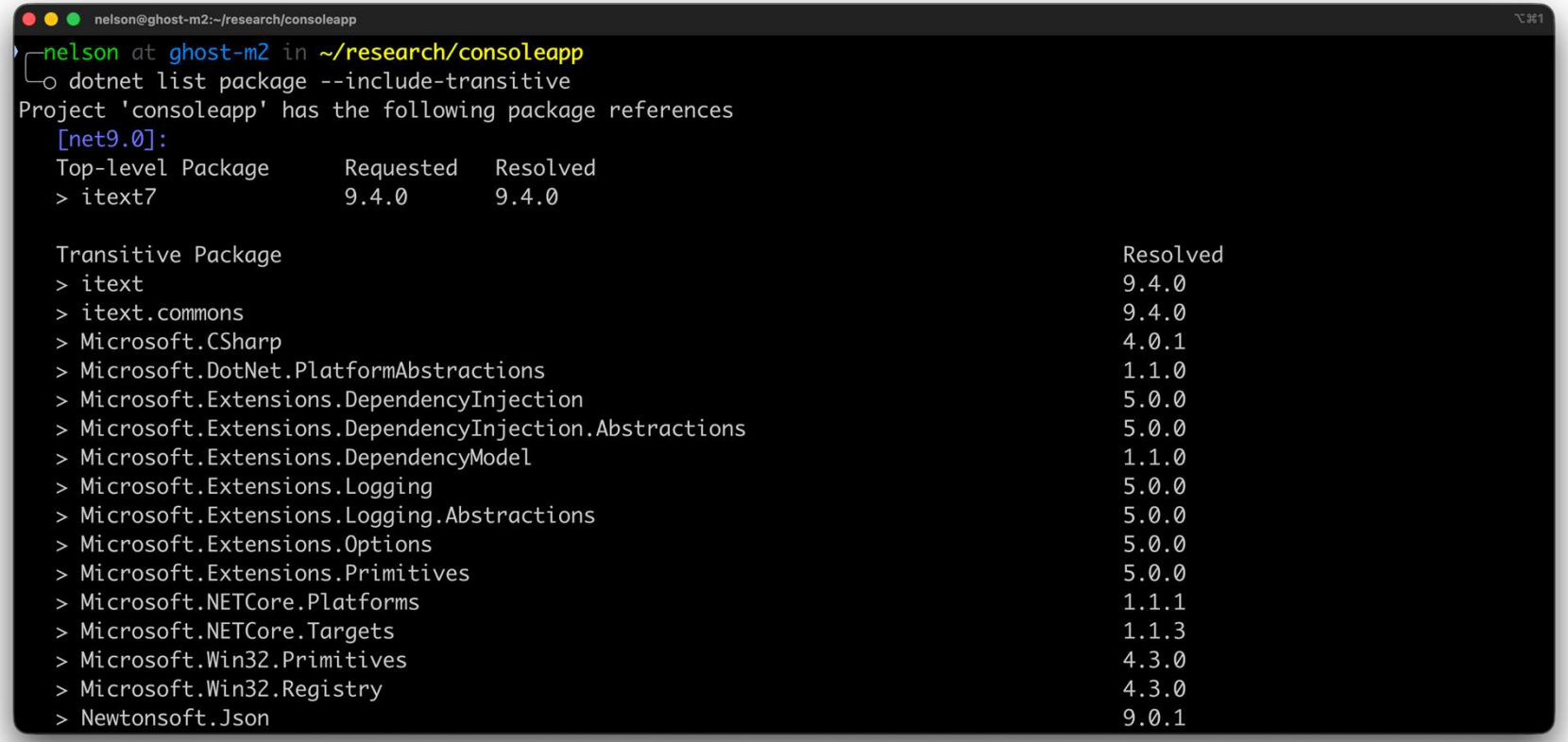
DotNet CLI

#UCK26



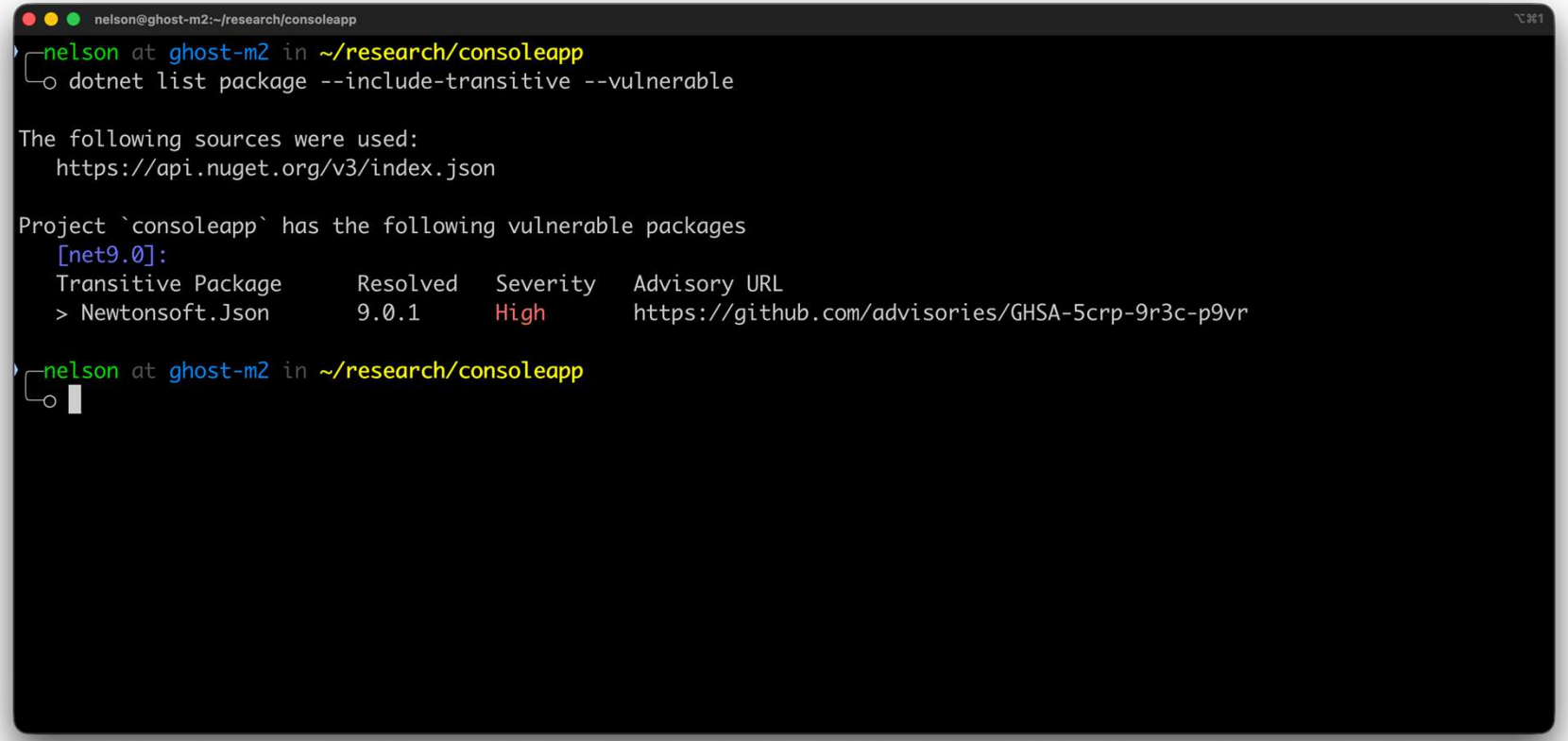
DotNet CLI

#UCK26



DotNet CLI

#UCK26

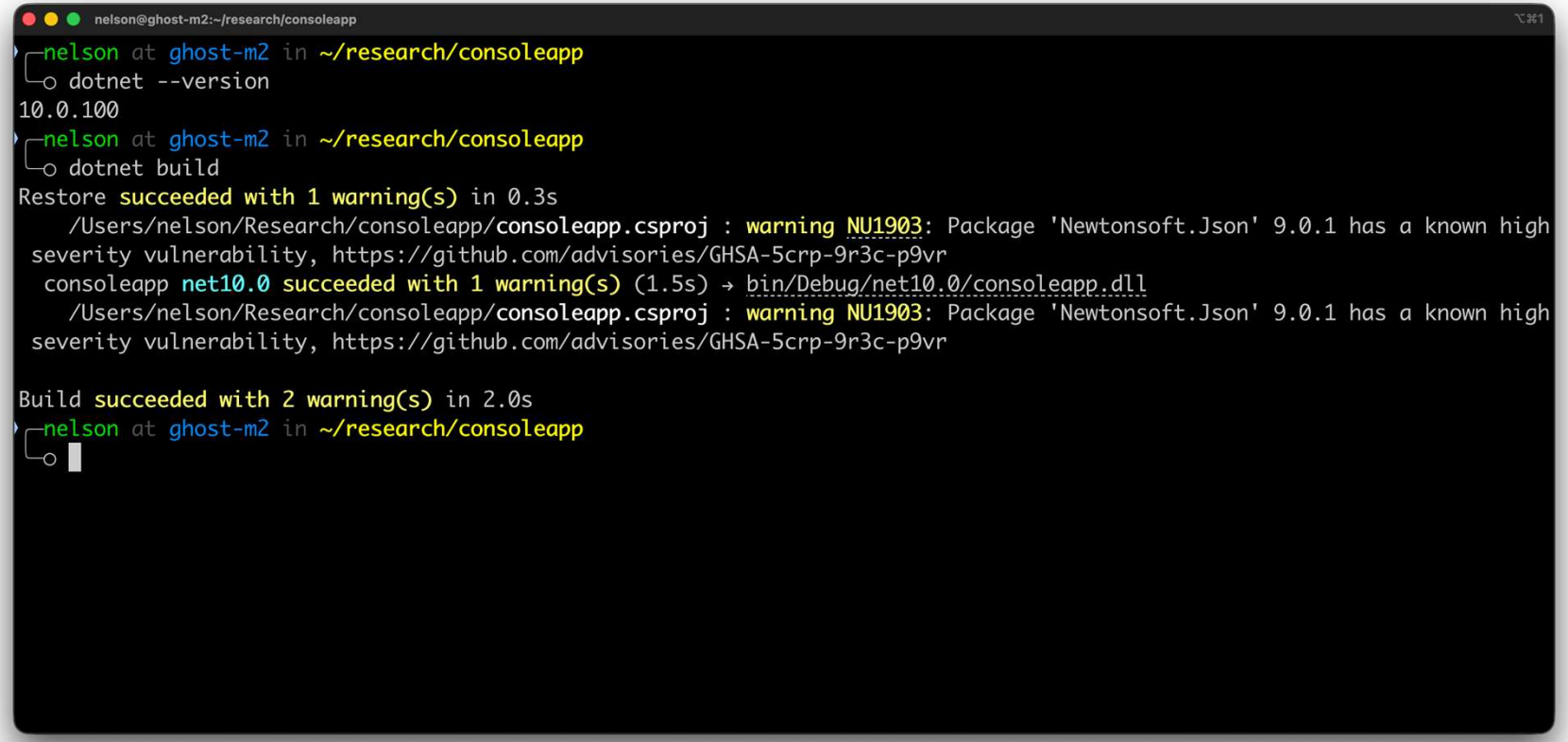


TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

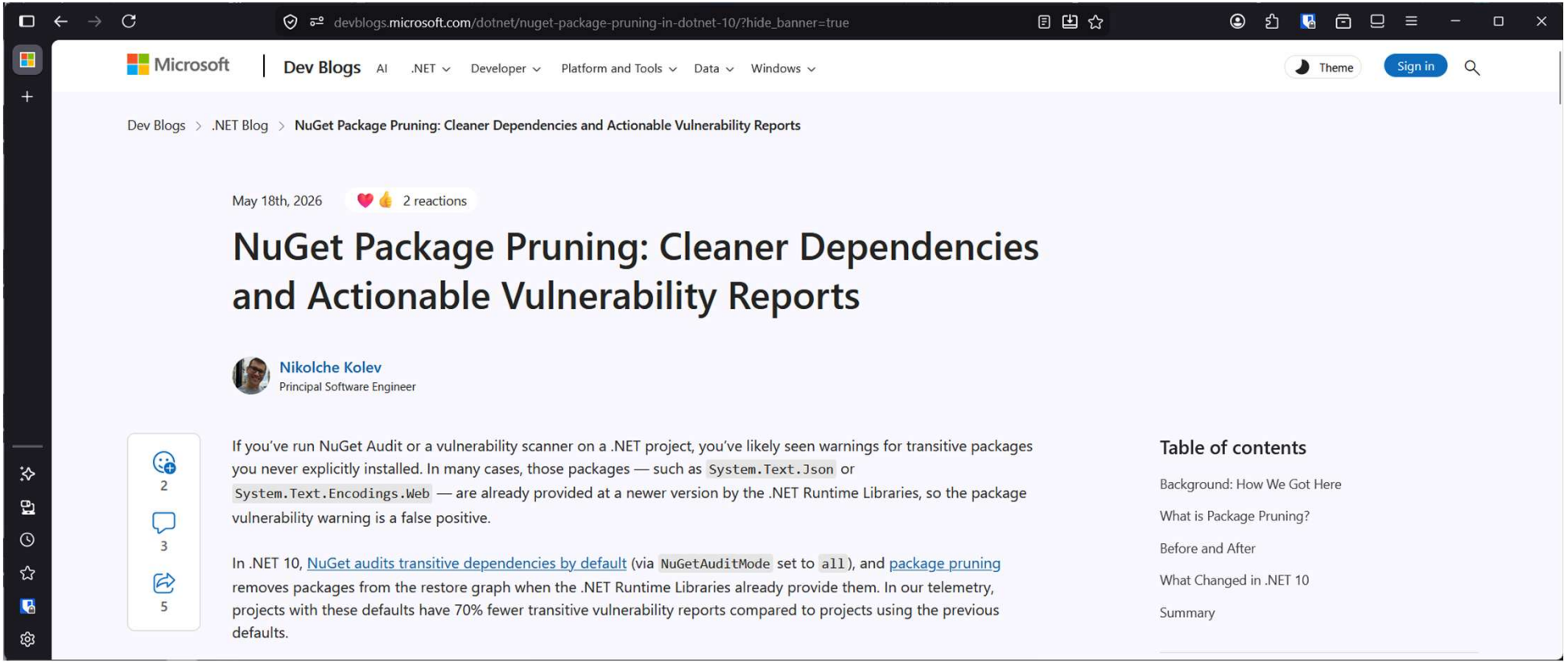
DotNet CLI - .NET 10

#UCK26



NuGet Package Pruning

#UCK26

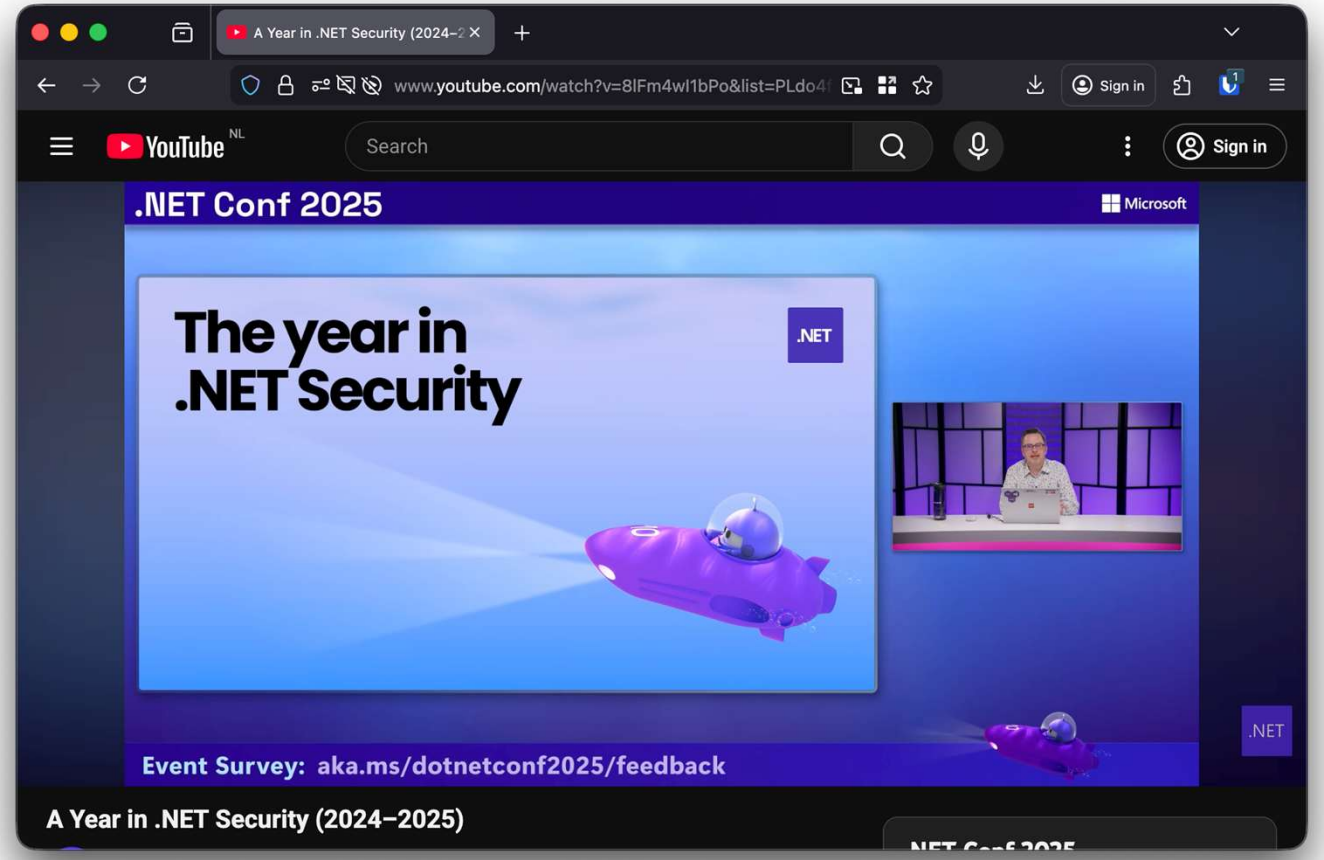


TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

.NET Conf 2025 – The year in .NET Security

#UCK26

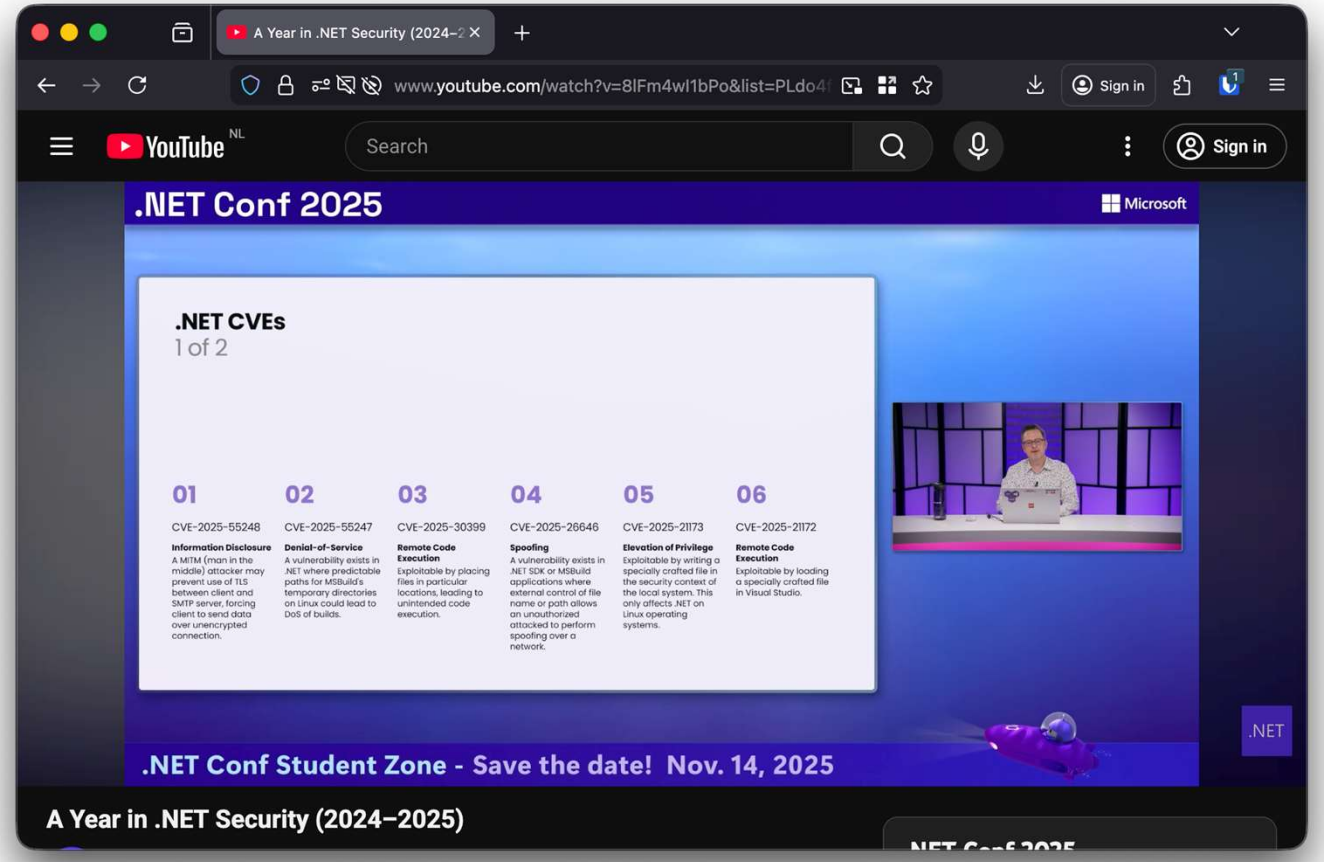


TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

.NET Conf 2025 – The year in .NET Security

#UCK26

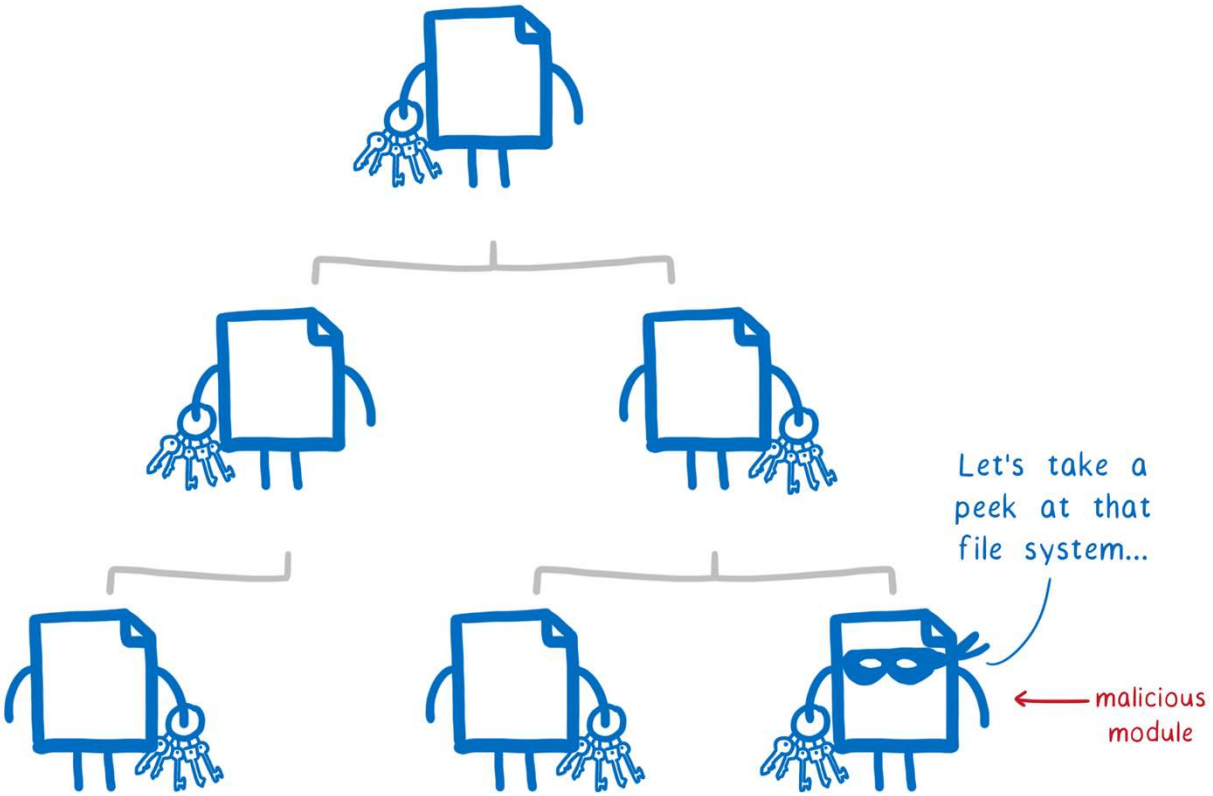


TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

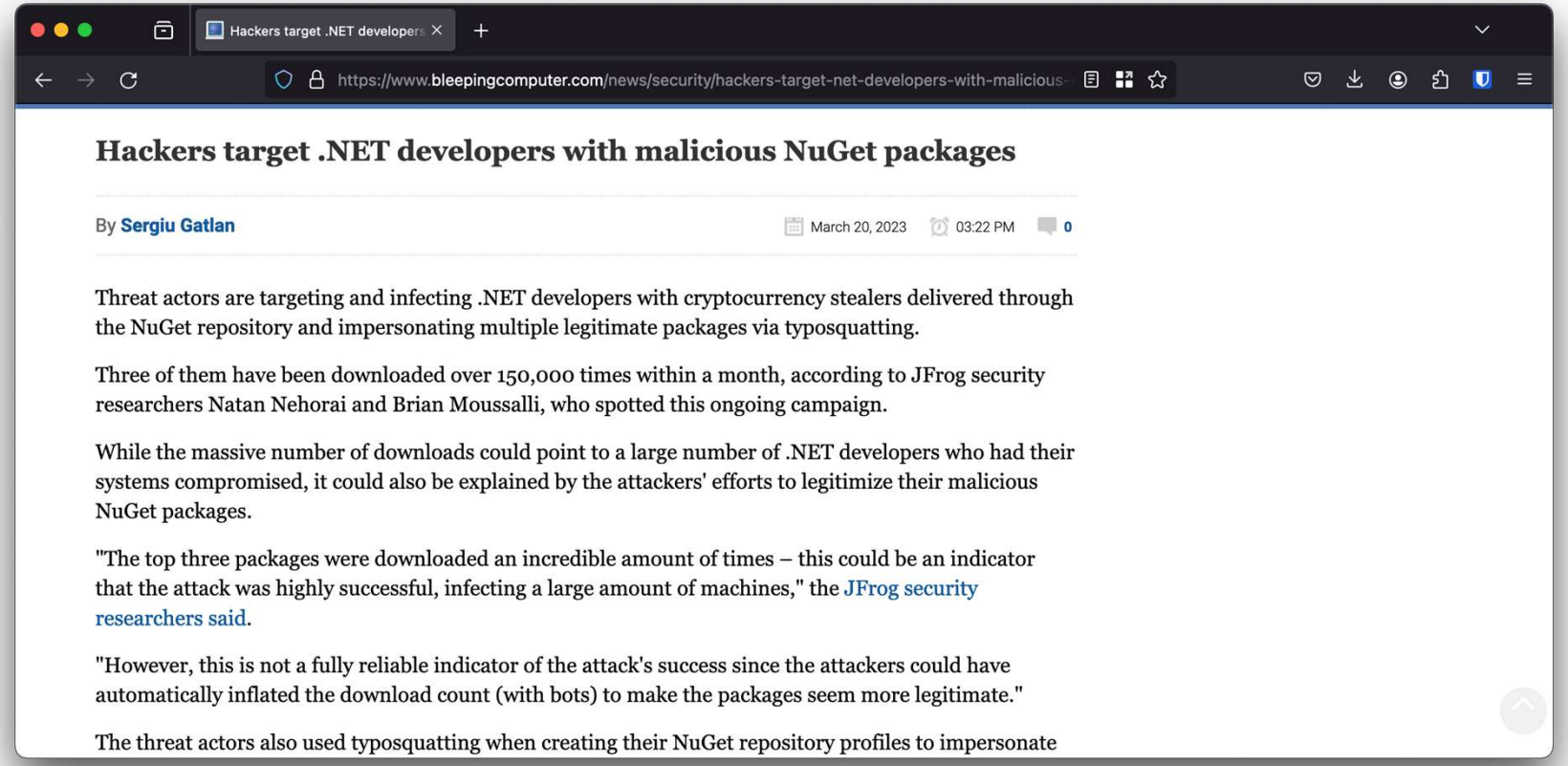
Malicious Assembly

#UCK26



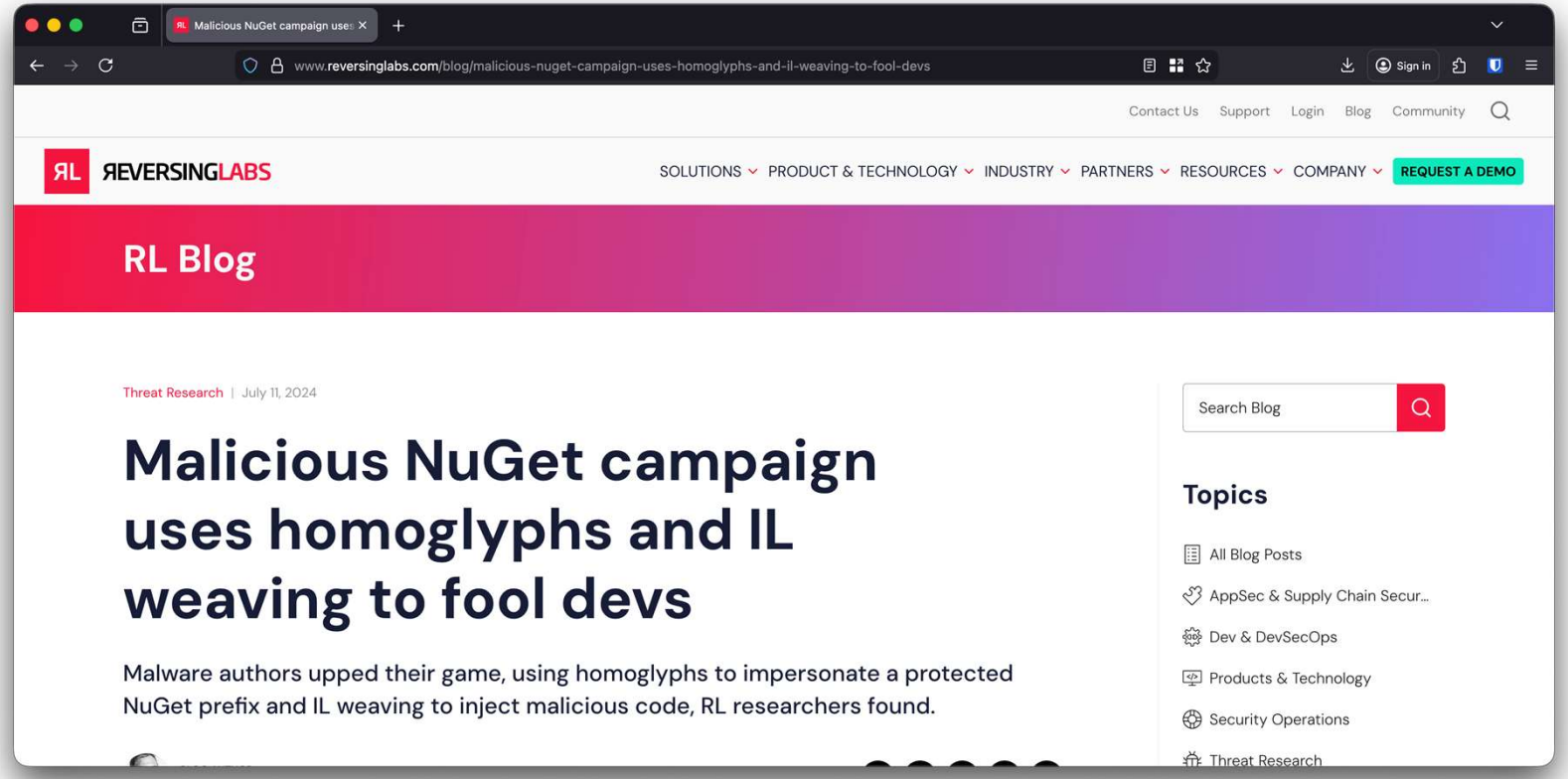
Malicious Package

#UCK26



Malicious Package

#UCK26

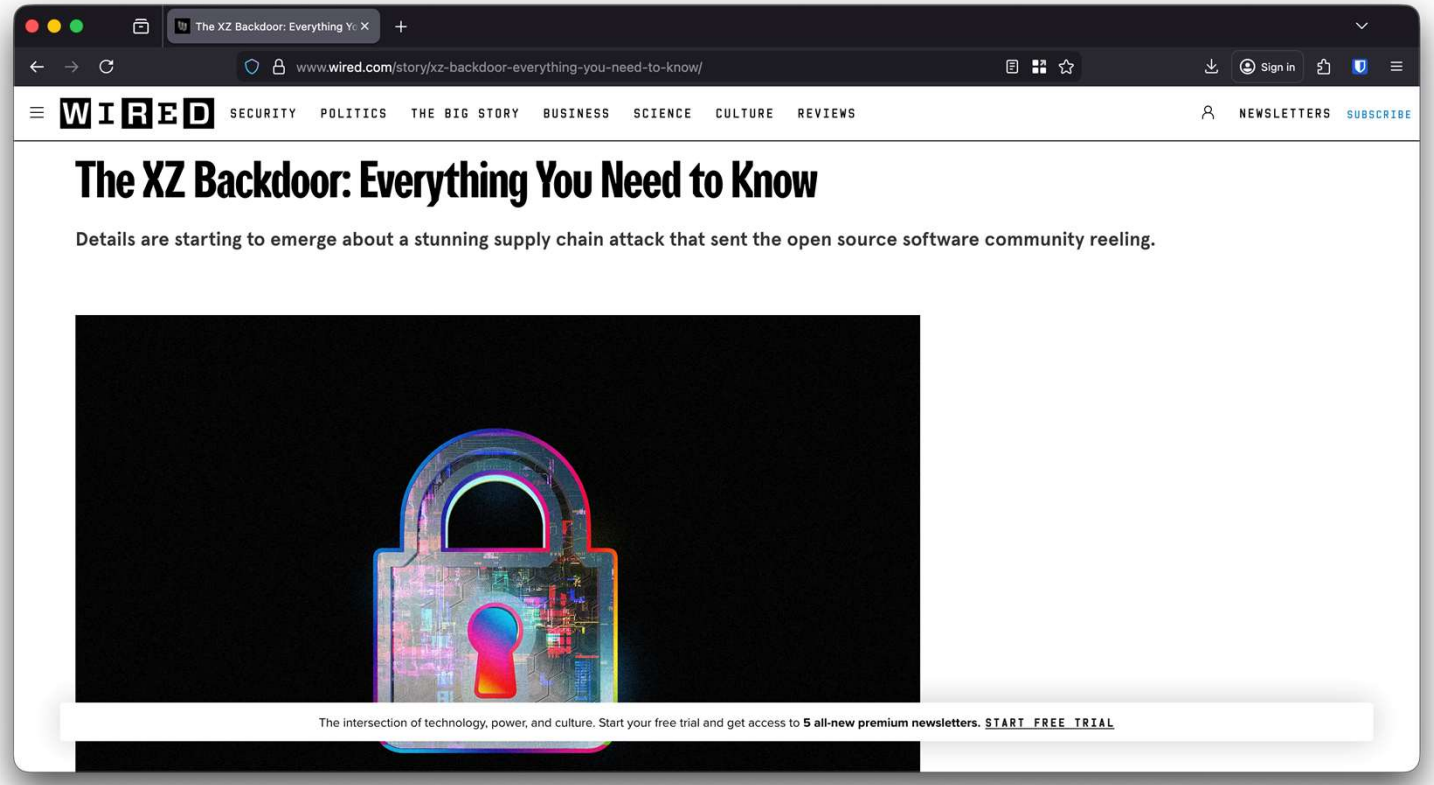


TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

Do you know what's inside? – xz utils

#UCK26

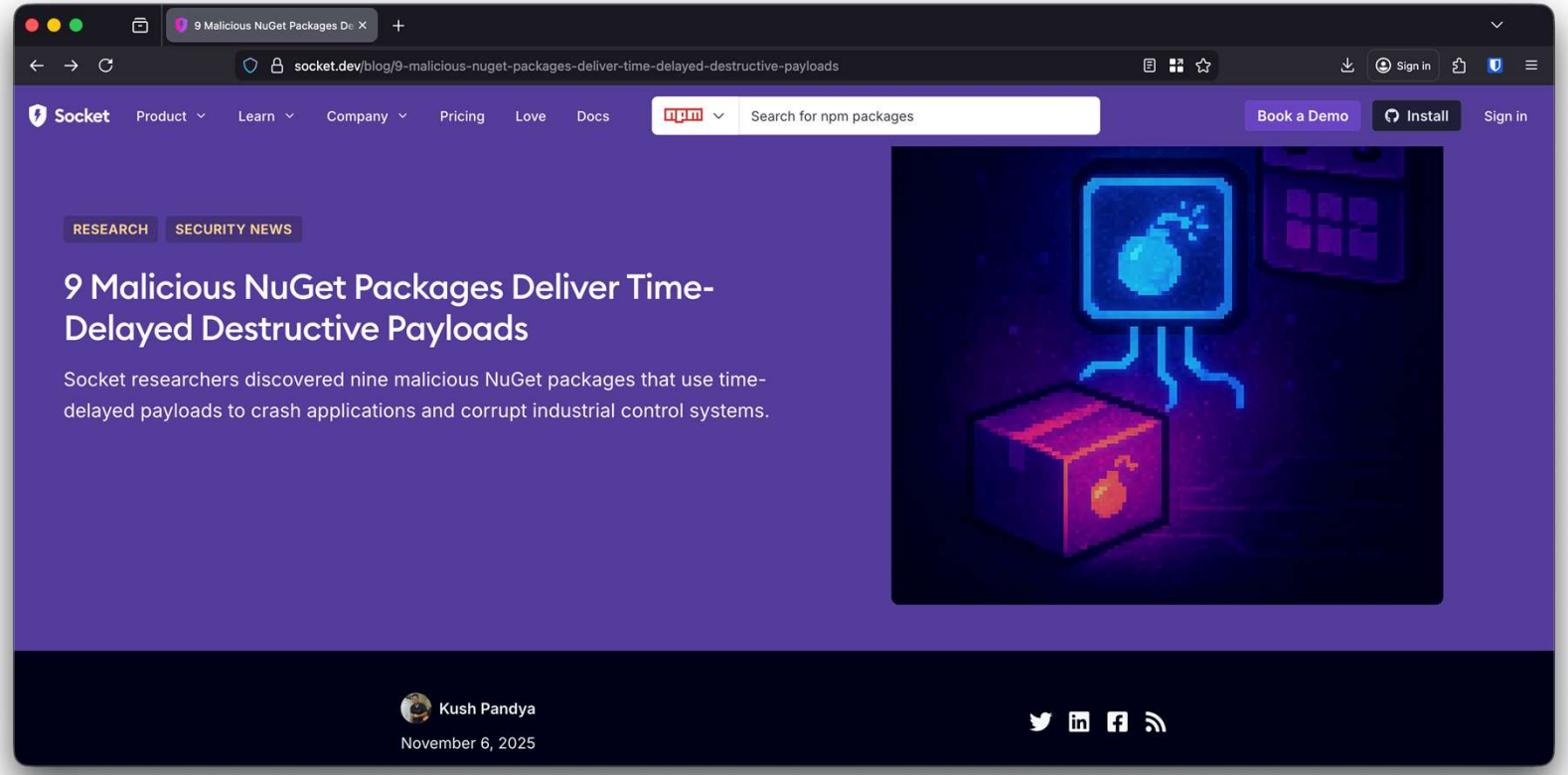


TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

Malicious Package

#UCK26



TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

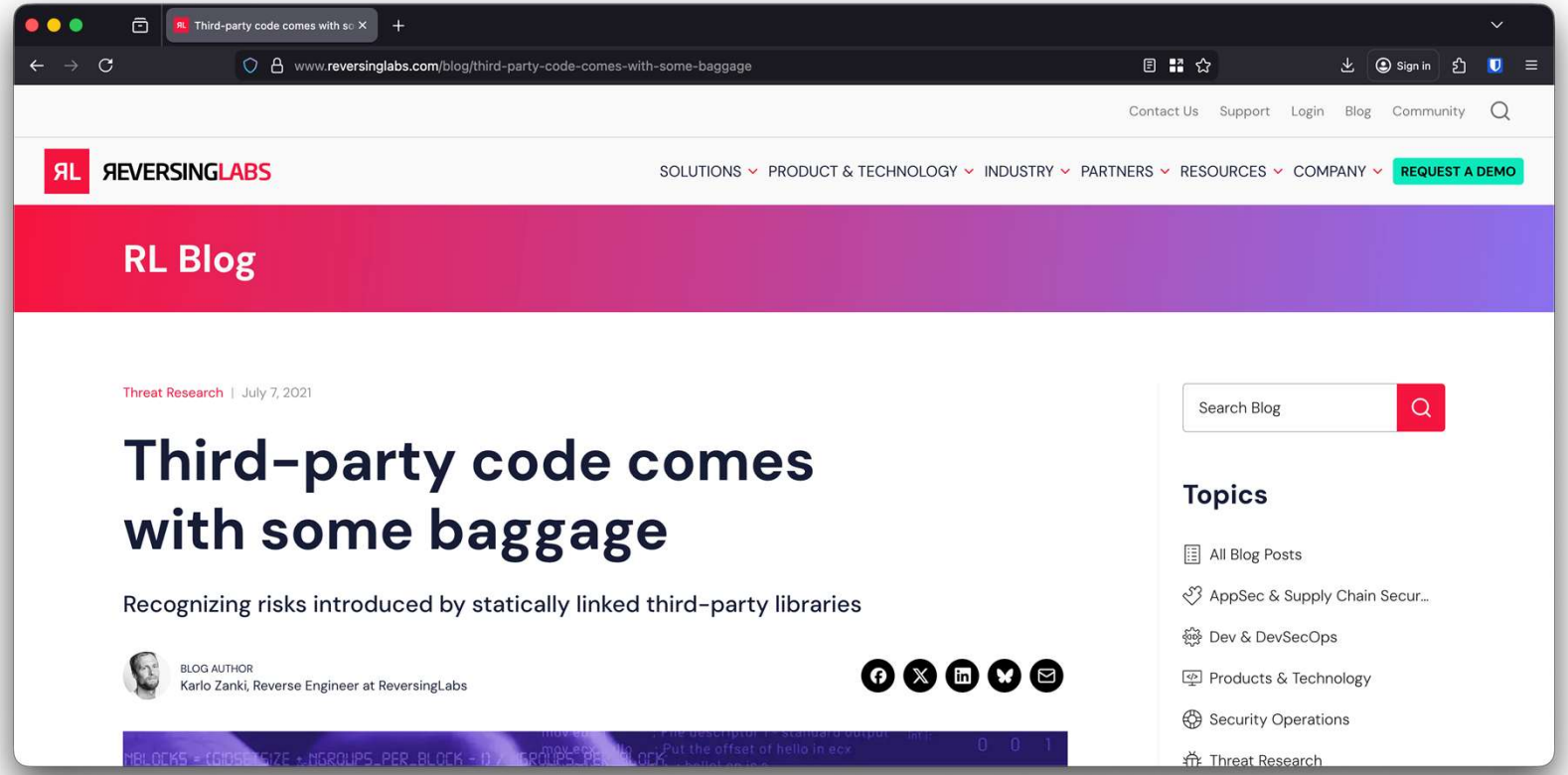
Malicious Package

#UCK26

- Single publisher called **shanhai666**
- 99% code is valid & functional focusing on databases and industrial PLC's, malicious extension methods
- Delayed logic for Aug '27 & Nov '28
- 20% of database queries are terminated
- Sharp7Extend (typo squatting) for PLC, immediate activation mimics hardware failures

Do you know what's inside?

#UCK26



TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

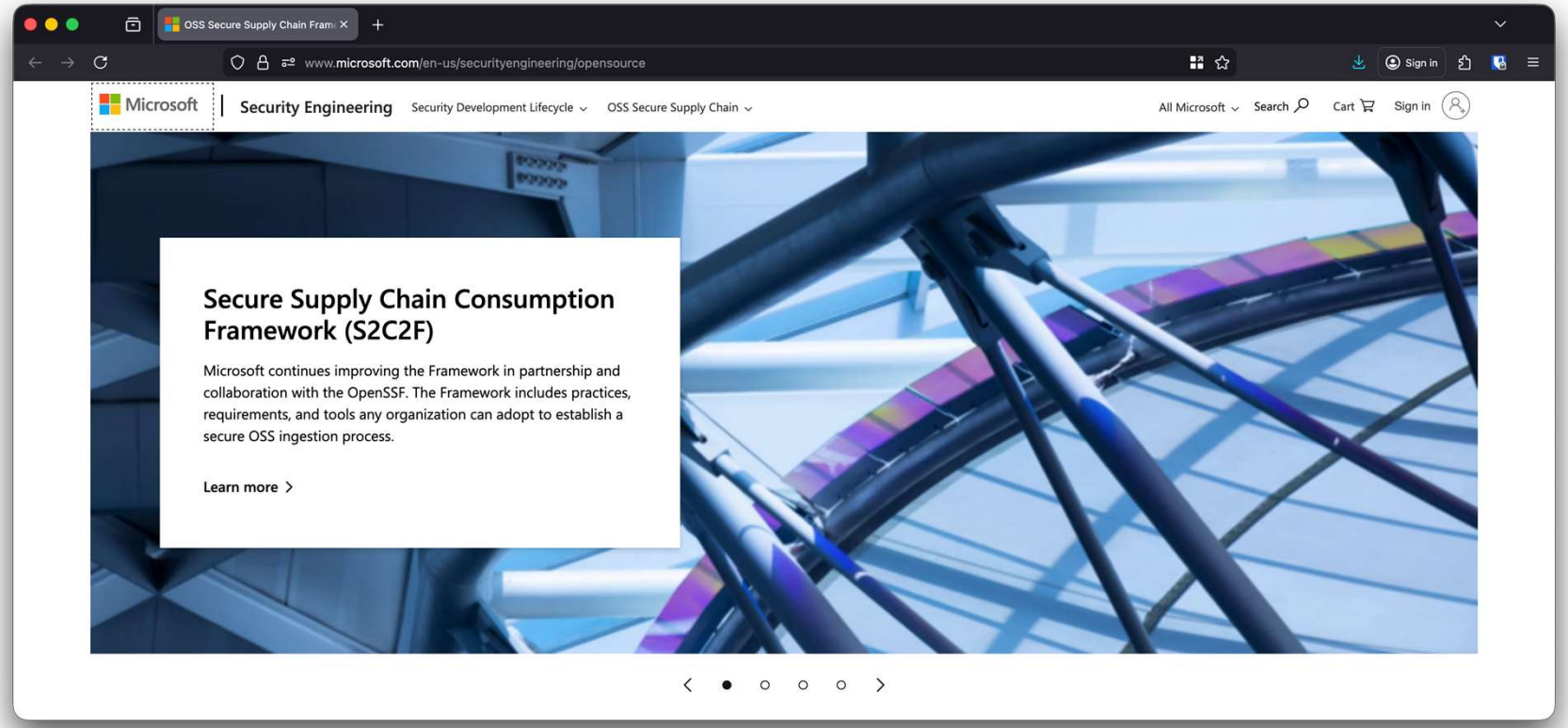
Do you know what's inside?

#UCK26

- Unmanaged components interop
- Precompiled version of 7Zip, WinSCP and PuTTYgen
- Zlib compression library
  - Only source code distributed
  - Used in medical appliances
  - Severe vulnerabilities since 2005!

Secure Supply Chain Consumption Framework (S2C2F)

#UCK26



TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

Secure Supply Chain Consumption Framework (S2C2F)

#UCK26

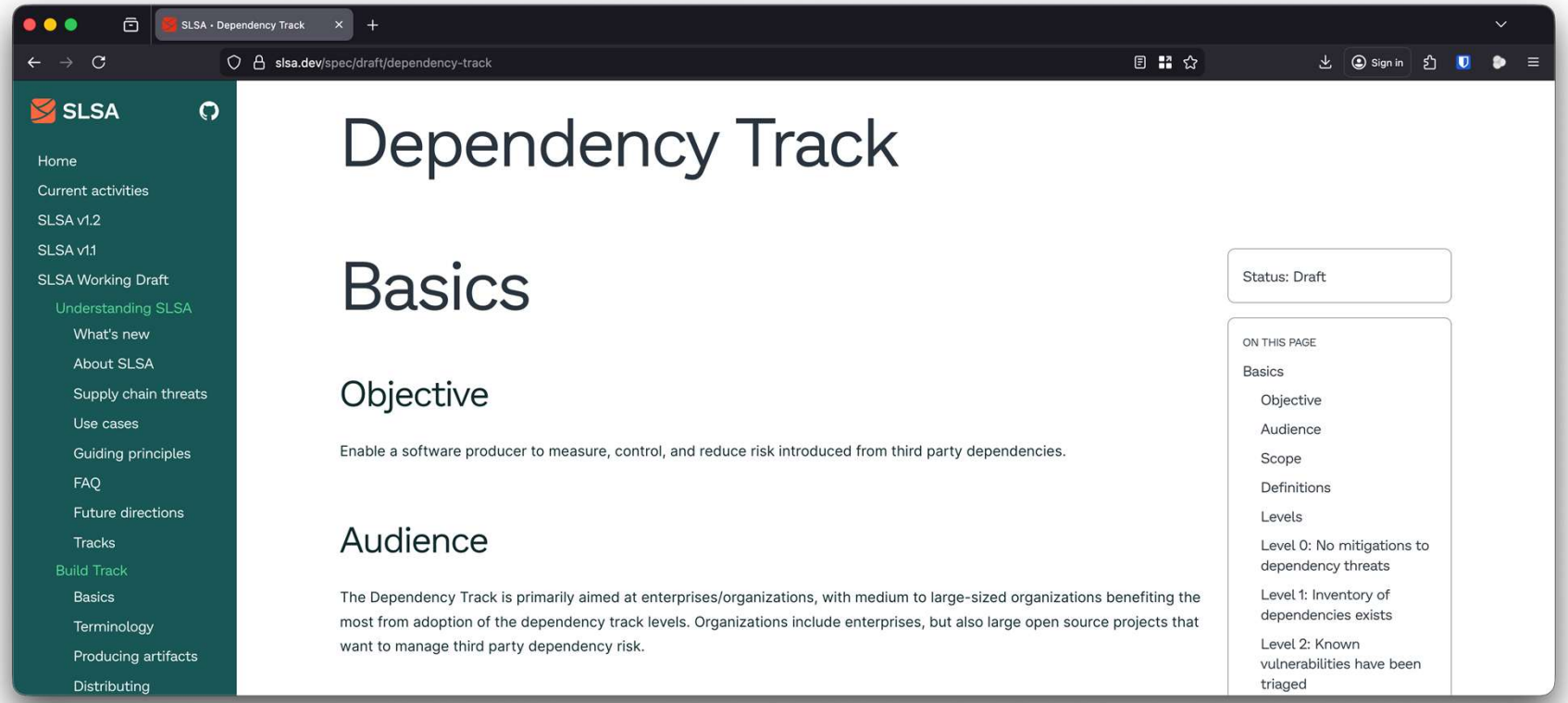
Level 1	Level 2	Level 3	Level 4
Minimum OSS Governance Program • Use package managers [ING-1] • Local copy of artifact [ING-2] • Scan with known vulns [SCA-1] • Scan for software licenses [SCA-2] • Inventory OSS [INV-1] • Manual OSS updates [UPD-1]	**Secure Consumption and Improved MTTR** • Scan for end of life [SCA-3] • Have an incident response plan [INV-2] • Auto OSS updates [UPD-2] • Alerts on vulns at PR time [UPD-3] • Audit that consumption is through approved ingestion method [AUD-2] • Validate integrity of OSS [AUD-3] • Secure package source file configuration [ENF-1]	**Malware Defense and Zero-Day Detection** • Deny list capability [ING-3] • Clone OSS source [ING-4] • Scan for malware [SCA-4] • Proactive security reviews [SCA-5] • Enforce OSS provenance [AUD-1] • Enforce consumption from curated feed [ENF-2]	**Advanced Threat Defense** • Validate the SBOMs of OSS consumed [AUD-4] • Rebuild OSS on trusted infrastructure [REB-1] • Digitally sign rebuilt OSS [REB-2] • Generate SBOM for rebuilt OSS [REB-3] • Digitally sign protected SBOMs [REB-4] • Implement fixes [FIX-1]

TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

S2C2F → SLSA Dependency Track

#UCK26

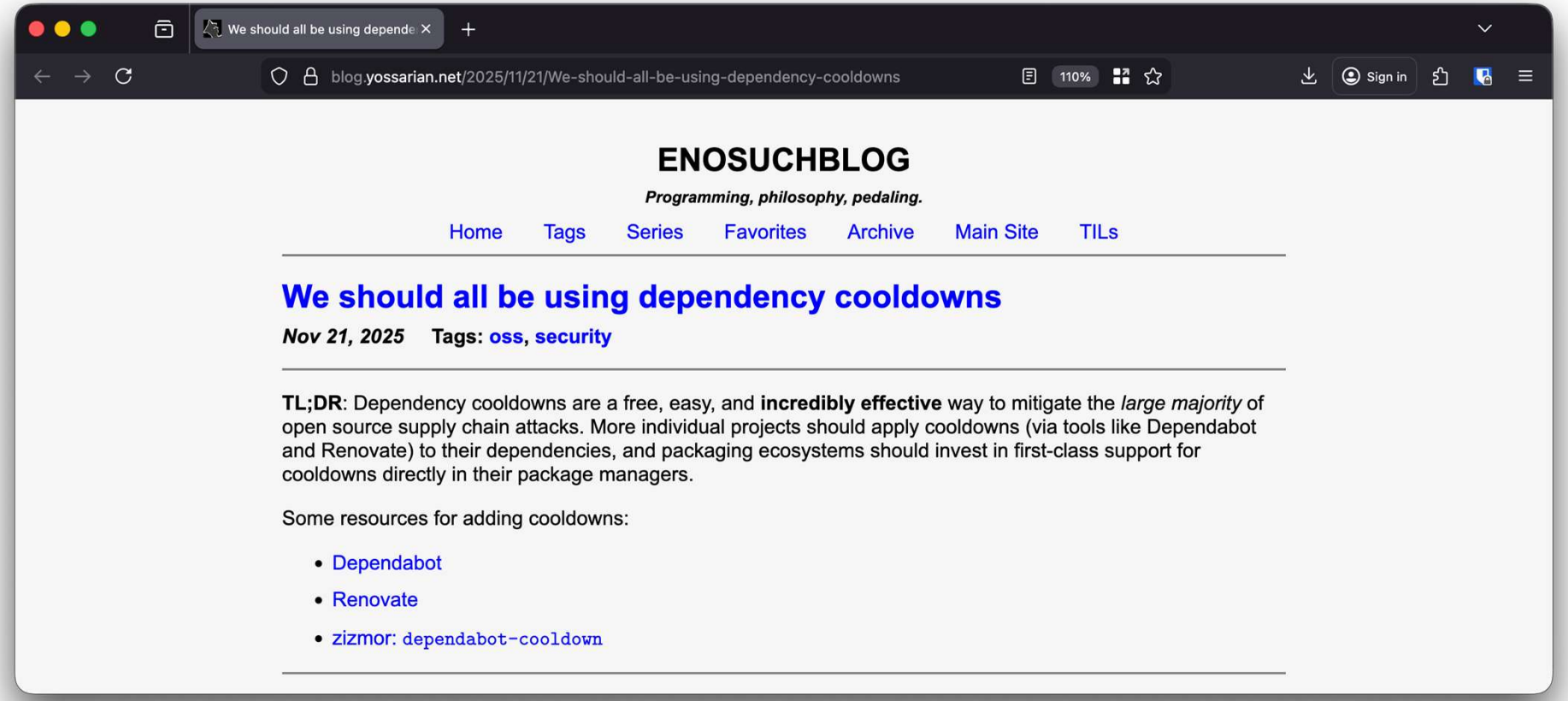


TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

Hot take; dependency cooldowns

#UCK26



TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

What's inside? (Audit)

#UCK26

@niels.fennec.dev @nielstanis@infosec.exchange

Open SSF Security Scorecard

#UCK26

- Set Automated Security Checks
- Scoring System 0-10
- Security Best Practices
- Ease of Use
- Community Support

TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

Maintenance

#UCK26

- Vulnerabilities (**High**)
  - Does the project have unfixed vulnerabilities?
- Maintained (**High**)
  - Is the project at least 90 days old, and maintained?
- Security Policy (**Medium**)
  - Does project contain security policy?

Maintenance

#UCK26

- License (Low)
  - Does the project declare a licence?
- CII Best Practices (Low)
  - Does the project have a CII Best Practices Badge?
- Dependency Update Tool (High)
  - Does the project use tools to help update its dependencies e.g. Dependabot, RenovateBot?

Continous Testing

#UCK26

- Continuous Integration Tests (Low)
  - Does the project run tests in CI?
- Fuzzing (Medium)
  - Does the project use fuzzing tools, e.g. OSS-Fuzz?
- Static Analysis (Medium)
  - Does the project use static code analysis tools?

Source Risk Assessment

#UCK26

- Binary Artifacts (**High**)
  - Does repository contain binaries/compiled artifacts?
- Branch Protection (**High**)
  - GitHub best practices branch protection
- Dangerous Workflow (**Critical**)
  - GitHub best practices for Workflow Actions

@niels.fennec.dev @nielstanis@infosec.exchange

Source Risk Assessment

#UCK26

- Code Review (**High**)
  - Does the project require code review before code is merged?
- Contributors (Low)
  - Does the project have contributors from multiple organizations?

Build Risk Assessment

#UCK26

- Pinned Dependencies (Medium)
  - Does the project declare and pin dependencies?
- Token Permission (High)
  - Does the project declare GitHub workflow tokens as read only?

Build Risk Assessment

#UCK26

- Packaging (Medium)
  - Does the project build and publish official packages from CI/CD?
- Signed Releases (High)
  - Does the project cryptographically sign releases?

Demo OpenSSF Scorecard

#UCK26

```
Running checks
```

TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

Fennec Labs Scorecard

#UCK26

TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

Fennec Labs Instrument

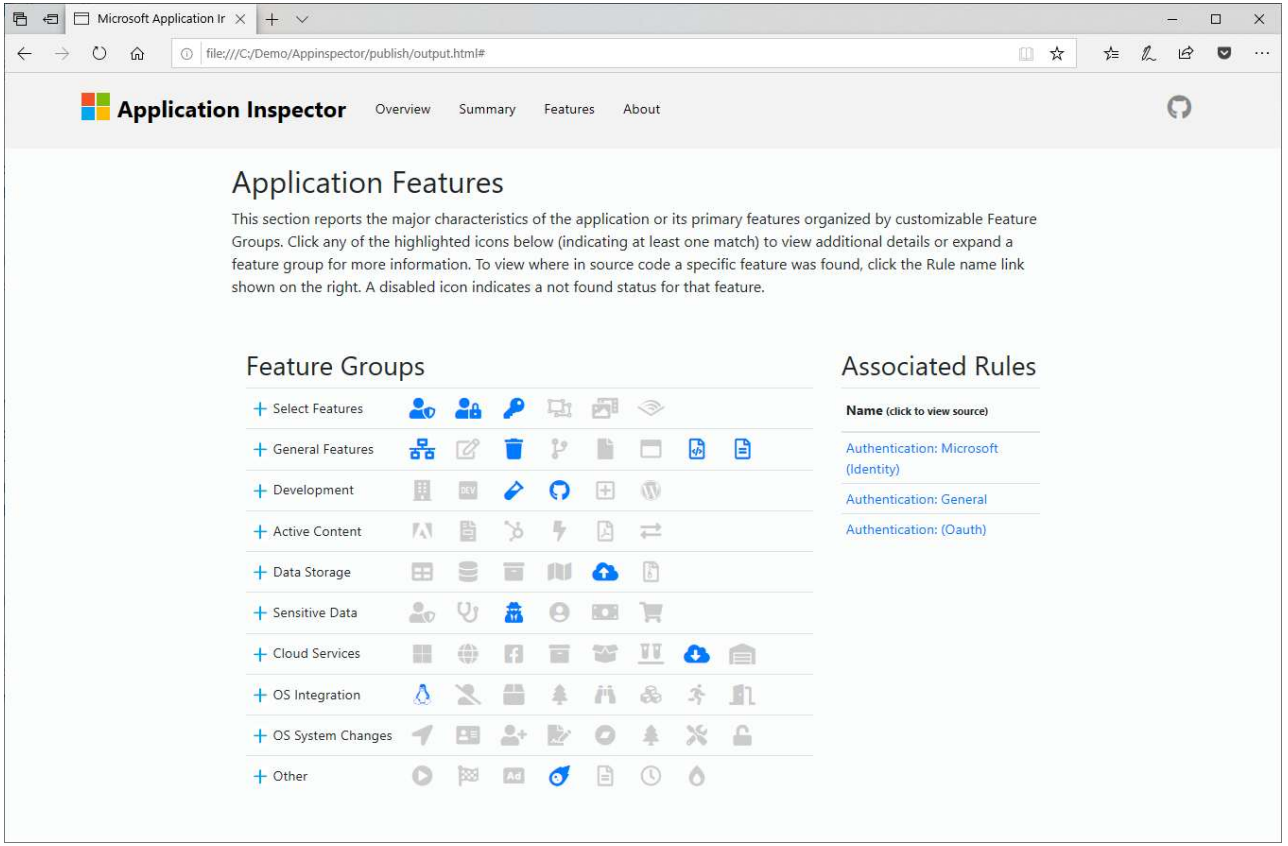
#UCK26

TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

Application Inspector

#UCK26

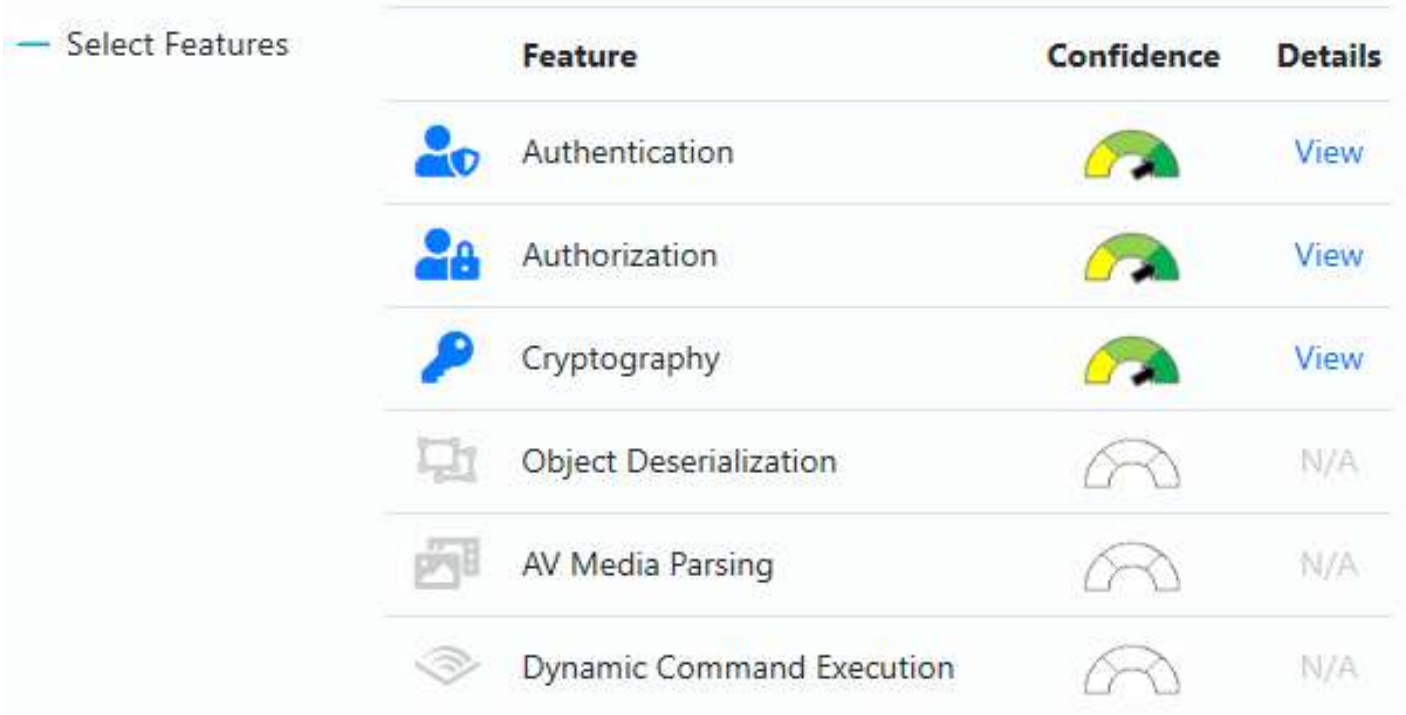


TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

Application Inspector

#UCK26



.NET Reproducibility

#UCK26

- Reproducible builds
  - Independent path from source to binary code.
- Roslyn Compiler Deterministic Compilation
- How reproducible is a simple console app?
  - Demo script available in repository

Fennec Labs Reproduce

#UCK26

TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

Fennec Labs Compare

#UCK26

TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

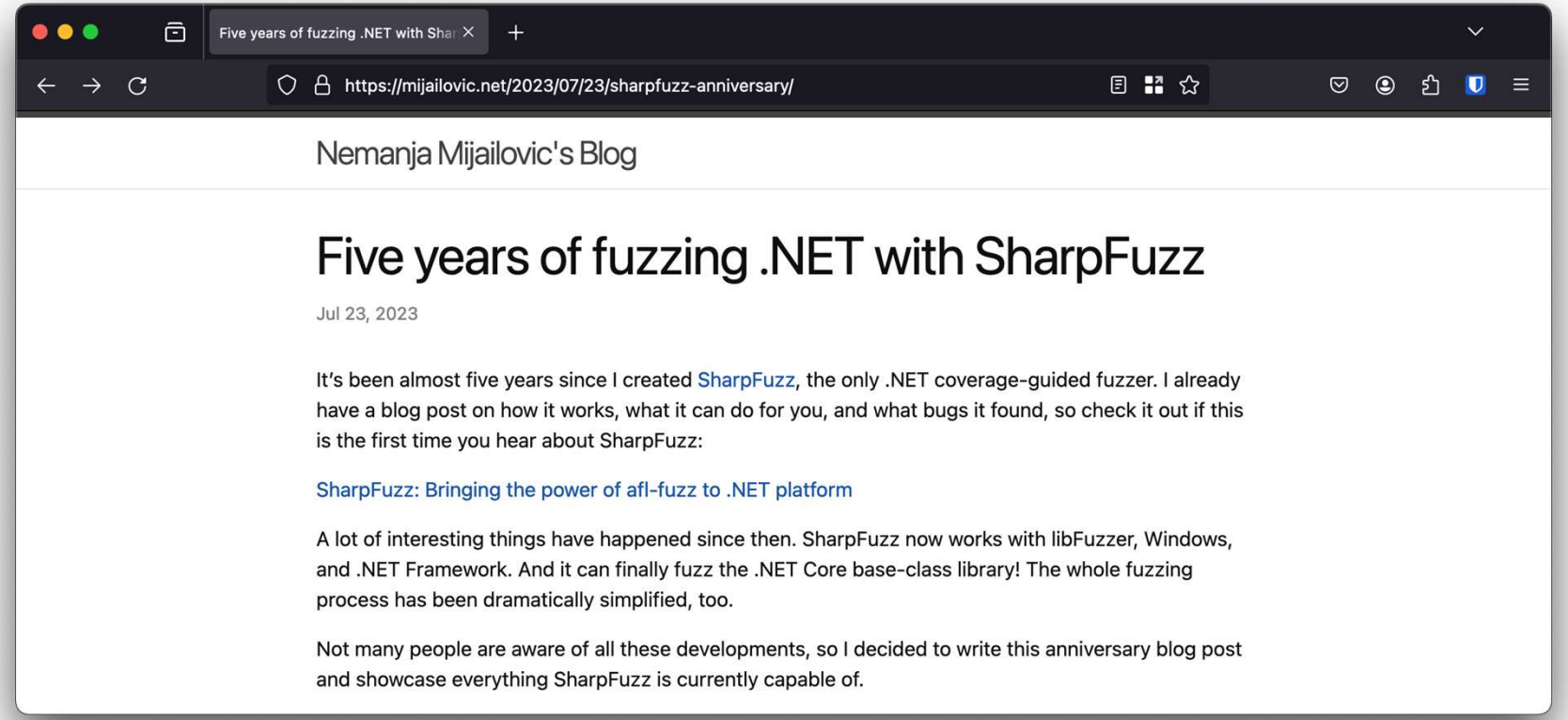
Future Idea - Fuzzing

#UCK26

- Fuzzing, or fuzz testing
  - Automated software testing method that uses a wide range of ***invalid*** and unexpected data as input to find flaws
- Good in C/C++ memory issues
- Can it be of any value with managed languages like .NET?

Fuzzing .NET & SharpFuzz

#UCK26

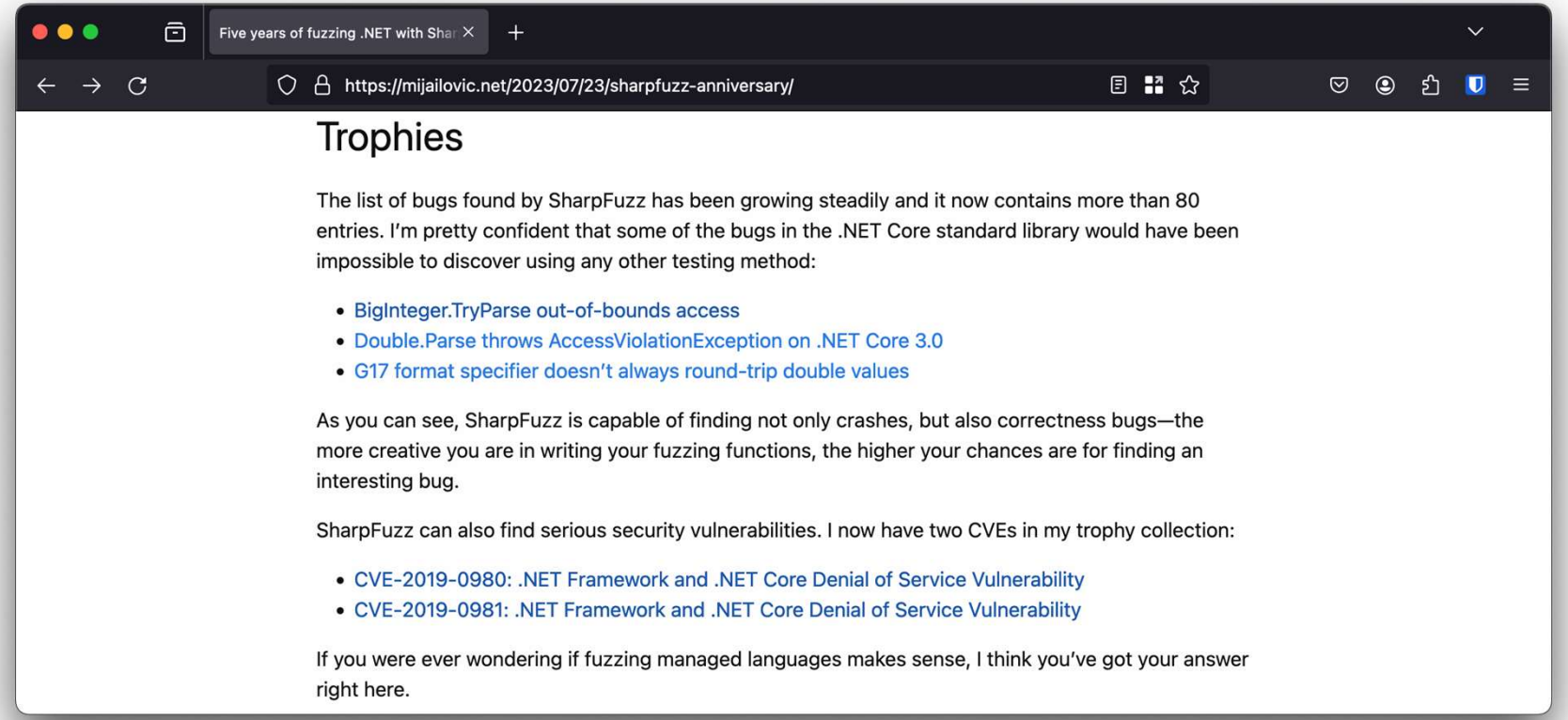


TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

Fuzzing .NET & SharpFuzz

#UCK26



Trophies

The list of bugs found by SharpFuzz has been growing steadily and it now contains more than 80 entries. I'm pretty confident that some of the bugs in the .NET Core standard library would have been impossible to discover using any other testing method:

- BigInteger.TryParse out-of-bounds access
- Double.Parse throws AccessViolationException on .NET Core 3.0
- G17 format specifier doesn't always round-trip double values

As you can see, SharpFuzz is capable of finding not only crashes, but also correctness bugs—the more creative you are in writing your fuzzing functions, the higher your chances are for finding an interesting bug.

SharpFuzz can also find serious security vulnerabilities. I now have two CVEs in my trophy collection:

- CVE-2019-0980: .NET Framework and .NET Core Denial of Service Vulnerability
- CVE-2019-0981: .NET Framework and .NET Core Denial of Service Vulnerability

If you were ever wondering if fuzzing managed languages makes sense, I think you've got your answer right here.

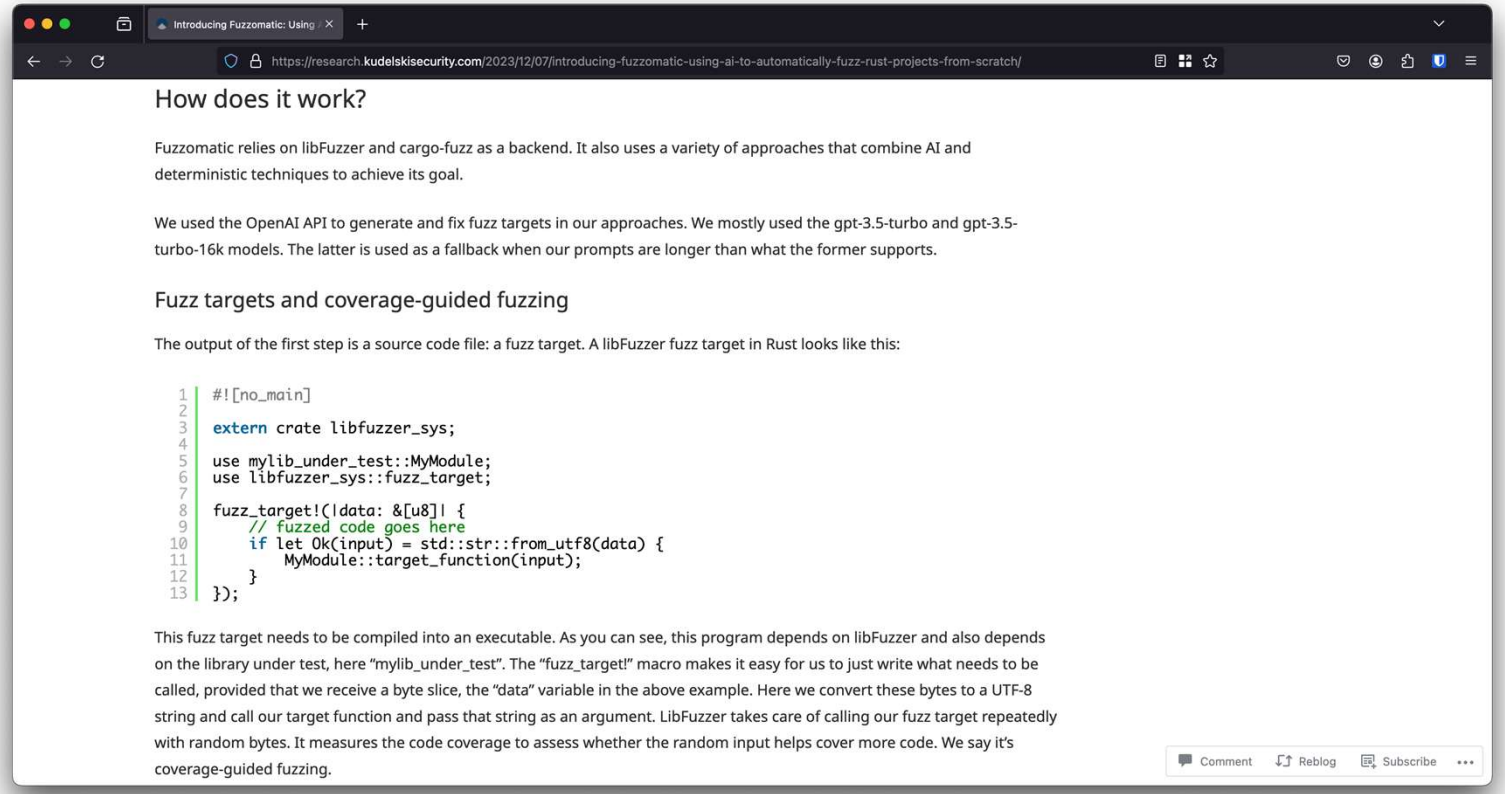
Fuzzing .NET – Jil JSON Serializer

#UCK26

```
public static void Main(string[] args)
{
        SharpFuzz.Fuzzer.OutOfProcess.Run(stream => {
        try
        {
                using (var reader = new
                        System.IO.StreamReader(stream))
                JSON.DeserializeDynamic(reader);
        }
        catch (DeserializationException) { }
        });
}
```

Fuzzomatic: Using AI to Fuzz Rust

#UCK26



TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange

Future Idea – Dashboard & Feedback

#UCK26

- Local and remote dashboard?
- Ability to do review and share security related data of project
- MCP server with embedded prompt resources to help security review
- Roslyn analyzer that can help guide the developer

Conclusion

#UCK26

- Doing software security is hard and Software Security Professionals don’t scale!
- Package eco-systems have been wild west lately
- Goal is to have Fennec Labs help with reviewing and sharing security details for all audiences
- Allowing everyone to make better informed decisions and can act if needed.

@niels.fennec.dev @nielstanis@infosec.exchange

Thank you!

#UCK26

- niels at fennec.dev
- https://github.com/nielstanis/updateconfkrakow2026
- Questions?

TIDALIS

@niels.fennec.dev @nielstanis@infosec.exchange